

TSEC Risk & Cyber Advisory LLC

Integrated Cybersecurity, Risk & Compliance Advisory

GUIDE-SOC2-01

What is SOC 2

A Practical Introduction to the AICPA Trust Services Criteria Framework

TSEC Compliance Insights | SOC 2 Series

Document ID:	GUIDE-SOC2-01
Version:	2026 Edition
Effective Date:	June 2026
Classification:	CONFIDENTIAL
Prepared by:	TSEC Risk & Cyber Advisory LLC

TSEC Compliance Insights | TSEC Risk & Cyber Advisory LLC | www.tsecgrc.com | info@tsecgrc.com

1. Introduction: Why SOC 2 Matters

If your organization provides technology services to other businesses — SaaS platforms, cloud infrastructure, data processors, managed service providers — your customers will almost certainly ask you one question: "How do we know your security controls protect our data?" SOC 2 is the most widely recognized framework for answering that question with independent, auditor-verified evidence.

SOC 2 stands for System and Organization Controls 2. It is a framework developed by the American Institute of Certified Public Accountants (AICPA) that evaluates whether a service organization's controls meet defined criteria for security, availability, processing integrity, confidentiality, and privacy — collectively known as the Trust Services Criteria (TSC). This guide explains what SOC 2 is, how it works, who needs it, and what it takes to achieve it.

2. The Trust Services Criteria

The Trust Services Criteria are the yardstick against which a service organization's controls are measured. There are five TSC categories:

Category	What It Means	Who Typically Includes It
Security (CC)	Controls protect the system against unauthorized access, both physical and logical. This is the only mandatory category — every SOC 2 report must include Security.	All service organizations
Availability (A)	Controls ensure the system is available for operation and use as committed or agreed.	Organizations with uptime commitments or SLAs
Processing Integrity (PI)	Controls ensure system processing is complete, valid, accurate, timely, and authorized.	Organizations processing financial transactions or business-critical data
Confidentiality (C)	Controls protect information designated as confidential per agreements with customers.	Organizations handling sensitive business or customer data
Privacy (P)	Controls address the collection, use, retention, disclosure, and disposal of personal information in accordance with commitments.	Organizations handling consumer or employee personal data

The Security category is organized around nine common criteria (CC1 through CC9), addressing the control environment, communication and information, risk assessment, monitoring, control activities, logical and physical access, system operations, change management, and risk mitigation. These criteria draw heavily on the COSO framework and are designed to be technology-neutral and scalable across organizations of varying size.

3. Type I vs. Type II: What Is the Difference?

SOC 2 examinations come in two types, and understanding the distinction is essential for knowing what a report actually tells you.

	SOC 2 Type I	SOC 2 Type II
What is tested?	The design and implementation of controls as of a single point in time	The design AND operating effectiveness of controls over a defined period (typically 6-12 months)
Time period	A single date (e.g., December 31)	A period of time (e.g., January 1 – December 31)

What it demonstrates	That controls are designed appropriately to meet the TSC	That controls are designed appropriately AND are actually working in practice over time
Customer expectation	A starting point; many customers require a Type II	The gold standard; most enterprise customers require a Type II report
Typical use case	Achieving initial certification; demonstrating progress in a readiness journey	Renewing annually; satisfying enterprise due diligence requirements

Most organizations begin with a Type I to validate their control design before committing to a Type II examination period. However, some organizations skip directly to a Type II, particularly when commercial pressure from customers is the primary driver.

4. Who Needs SOC 2?

SOC 2 is not legally mandated in the way that HIPAA or PCI DSS can be — it is a voluntary framework adopted because of market demand. Organizations most commonly pursue SOC 2 when:

- Enterprise customers include SOC 2 Type II in their vendor due diligence checklist as a prerequisite for signing a contract
- The organization handles sensitive data (financial records, health information, personal data) on behalf of clients
- The organization is growing from the mid-market into the enterprise segment and needs credible security assurance
- The organization is competing for government or regulated-industry contracts where independent assurance is expected
- The security and compliance team wants a structured framework for maturing internal controls and demonstrating continuous improvement

5. The SOC 2 Examination Process

5.1 Selecting a CPA Firm

SOC 2 examinations must be conducted by a licensed CPA firm. Not all auditors are equal — look for a firm with deep experience in technology sector SOC 2 examinations, a clear understanding of cloud and DevOps environments, and a reputation for producing reports that customers will actually rely upon. Smaller firms may offer more flexibility and cost efficiency; larger firms may carry more brand credibility with sophisticated enterprise buyers.

5.2 Defining the System and Scope

Before the examination begins, the organization and its auditor agree on the scope — the system or systems to be included, the TSC categories to be examined, and the examination period. Defining scope too narrowly risks customer scrutiny; defining it too broadly risks exposing immature controls to examination. A well-defined scope statement describes the services provided, the infrastructure supporting them, and the boundaries of what is and is not included.

5.3 Readiness Assessment

Most organizations — particularly those pursuing their first SOC 2 — benefit from a readiness assessment before the formal examination period begins. A readiness assessment identifies control gaps relative to the TSC and gives the organization time to remediate before auditors

begin testing operating effectiveness. TSEC's SOC 2 Readiness Roadmap provides a structured approach to this process.

5.4 Evidence Collection and Testing

During the examination, auditors test controls by reviewing documentation, interviewing personnel, observing processes, and inspecting systems. For a Type II examination, auditors sample evidence over the examination period — for example, reviewing a sample of access provisioning requests, change management tickets, or vulnerability scan results from across the year to confirm controls operated consistently.

5.5 The Report

A SOC 2 report contains: a management assertion (management's statement about the system); the auditor's opinion (whether controls met the TSC); a description of the system; a description of each control tested; the testing performed; and, for Type II, the results of testing, including any deviations. A 'clean' (unqualified) opinion means controls met the TSC throughout the period. Deviations are noted exceptions where a control did not operate effectively in every tested instance.

6. Common Control Areas

While every organization's controls will differ based on its technology stack and risk profile, certain control areas are universally scrutinized in SOC 2 examinations:

- Access control — how access to systems is provisioned, reviewed, and revoked; MFA requirements
- Change management — how code and configuration changes are tested, approved, and deployed
- Risk assessment — how the organization identifies and manages information security risks
- Vendor management — how third-party service providers are assessed and monitored
- Incident response — how security incidents are detected, responded to, and documented
- Availability and monitoring — how systems are monitored and how the organization maintains uptime commitments

7. Complementary User Entity Controls (CUECs)

A SOC 2 report often includes Complementary User Entity Controls — controls that the service organization assumes its customers (user entities) will implement. For example, a SaaS provider may note that customers are responsible for managing their own user access within the platform, or for ensuring their employees complete security awareness training. When customer security teams review a SOC 2 report, they are expected to assess whether they have implemented the CUECs applicable to them.

8. Key Takeaways

- SOC 2 is the market standard for demonstrating independent assurance of security controls to enterprise customers
- The only mandatory TSC category is Security — additional categories are included based on what you've committed to customers

- Type I reports validate control design; Type II reports validate operating effectiveness over time — most enterprise customers require Type II
- The examination is conducted by a licensed CPA firm; readiness work before the examination period is critical to a clean opinion
- Deviations in a report are not automatic disqualifiers, but they require explanation and remediation planning to satisfy customers

9. SOC 2 vs. SOC 1 and SOC 3

Organizations new to the SOC landscape sometimes encounter SOC 1 and SOC 3 reports and wonder how they relate to SOC 2. The three report types serve different purposes and different audiences.

Report Type	Purpose	Audience	Contents
SOC 1	Evaluates controls relevant to internal control over financial reporting (ICFR) at service organizations that affect their customers' financial statements	Customers' financial auditors; restricted distribution	Description of the system; auditor's opinion; control testing results (Type II)
SOC 2	Evaluates controls against the AICPA Trust Services Criteria for security, availability, processing integrity, confidentiality, and/or privacy	Customers, prospects, regulators; restricted distribution	Description of the system; auditor's opinion; TSC control testing results (Type II)
SOC 3	A simplified version of the SOC 2 report designed for general public distribution — no control details, just the auditor's opinion	General public; marketing use; unrestricted	Auditor's opinion only; no control description or testing detail

Most enterprise customers request SOC 2 reports, not SOC 3. SOC 3 is useful for marketing purposes — it can be posted publicly on your website to signal that a SOC 2 examination was completed and resulted in a clean opinion — but it does not provide customers with the detail they need for vendor due diligence.

10. Subservice Organizations and the Carve-Out Method

Most technology companies rely on cloud providers, managed service providers, and other third parties that are essential to their service delivery. These third parties are called subservice organizations in the SOC 2 context, and their role in your system must be disclosed and addressed in your SOC 2 report.

Organizations typically choose between two approaches:

Method	Description	Implications
Inclusive Method	The controls of the subservice organization are included in the scope of the examination and the auditor tests controls at both the service organization and the subservice organization	Requires auditor access to the subservice organization; rarely practical for large cloud providers
Carve-Out Method	The subservice organization is identified but its controls are excluded from the examination scope; users are informed of their existence and what controls are expected of them	Most common approach; service organization discloses the nature of services provided by subservice organizations; Complementary Subservice Organization Controls (CSOCs)

	describe what customers should look for in the subservice organization's own SOC 2
--	--

11. Reading a SOC 2 Report as a Customer

When you receive a vendor's SOC 2 report, the first thing most people do is jump to the auditor's opinion. That's understandable, but the auditor's opinion alone tells you less than you might think. Here's how to extract maximum value from a SOC 2 report:

- Step 1 — Check the opinion type: Is it qualified (exceptions noted that affect the opinion) or unqualified (clean)? A qualified opinion requires follow-up.
- Step 2 — Review the system description: Does it match what you thought you were buying? Are critical components like the database, network, or key third-party integrations described?
- Step 3 — Check what TSC categories are included: If you care about availability and only Security is included, the report doesn't cover what matters most to you.
- Step 4 — Review the testing results for deviations: Deviations are exceptions where a control didn't operate as described for one or more tested instances. A few minor deviations may be acceptable; recurring deviations in the same control area deserve a conversation with the vendor.
- Step 5 — Review the Complementary User Entity Controls (CUECs): What is the vendor assuming you're doing? Make sure you actually are doing it.
- Step 6 — Note the examination period: A report that ended 18 months ago tells you less about current security posture than one that ended last quarter. Ask vendors how frequently they renew their SOC 2 and request the most recent available report.

12. Frequently Asked Questions

Question	Answer
How much does a SOC 2 audit cost?	Costs vary widely by firm, scope, and organization size. A typical Type II audit for a small-to-mid-size SaaS company ranges from \$15,000 to \$50,000 for the audit itself, not including the cost of readiness work, tooling, and personnel time.
How long does the SOC 2 process take?	A Type I report can be achieved in 3-6 months from a strong baseline. A Type II requires a defined examination period (typically 6-12 months) plus fieldwork and reporting time — total timeline from starting readiness to receiving a Type II report is commonly 12-18 months.
Does SOC 2 expire?	SOC 2 reports don't expire, but they become stale. Enterprise customers generally expect a report covering the past 12 months. Most organizations renew annually.
Can a startup get SOC 2?	Yes. Many early-stage companies pursue SOC 2 to unlock enterprise sales. The challenge is implementing controls early enough that they can be shown to have operated effectively over the examination period.
Is SOC 2 required by law?	No — SOC 2 is a voluntary, market-driven framework. However, contracts with large customers often include SOC 2 as a contractual requirement, making it effectively mandatory for vendors who want those customers.